

Become a Wizard of Entra Workload Identities



Become a Wizard of Entra Workload Identities





Eric Woodruff

Chief Identity Architect @Semperis
Microsoft MVP (Identity & Access)

Lives in Schenectady, NY, USA



ericonidentity.com



ericonidentity.com



ericonidentity



ericonidentity



Thomas Naunheim

Cyber Security Architect @glueckkanja AG
Microsoft MVP (Identity & Access, Cloud Security)

Lives in Koblenz/Lahnstein, Germany



cloud-architekt.net



Naunheim.cloud



thomasnaunheim



Thomas_Live



THANK YOU TO OUR AMAZING SPONSORS !

glueckkanja

robopack
empowered by SOFTWARE
CENTRAL

nerdio

W

Continue

veeam

VARONIS

eido

Admin By Request
ZERO TRUST PLATFORM

Lenovo

dynatrace

VirtualMetric

Red Hat

Arkimentum

semperis

DanofficeIT

EPIC FUSION
BRING IT ALL TOGETHER

Recast

twoday

European
Power Platform
Conference
COPENHAGEN 29 JUNE - 02 JULY 2026

inforcer

APENTO

TRUESEC

Surveil

GLOBE SYSTEMS

control UP

PATCH
MY PC

JN DATA
WE ARE ON

systemcenterdudes

EasyEntra

Microsoft

Implora.io

Yealink

TD SYNnex

TOKEN
token2.swiss

Cloud Factory

GLOBETEAM

NORDSTERN

VENZO_
a valantic company

FEITIAN
WE BUILD SECURITY

identity stack

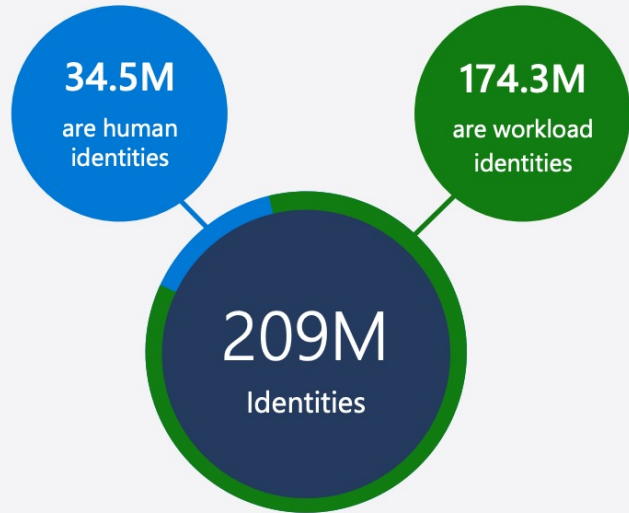
2LINKIT



Agenda

- Overview of workload identities
- Policies and secure delegation for workload owners
- Exploring the surface area for risk
- XDR threat protection and security posture

State of workload identity management



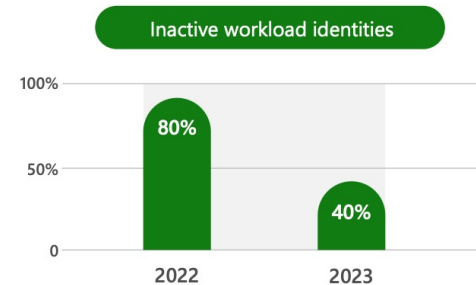
Of the 209M cloud identities identified in 2023,



There were 3 human super identities for every 7 workload super identities



Of the 174.3M workload identities identified



3% of workload identity permissions were used in 2023



Overview of Workload Identities



Security principals



User



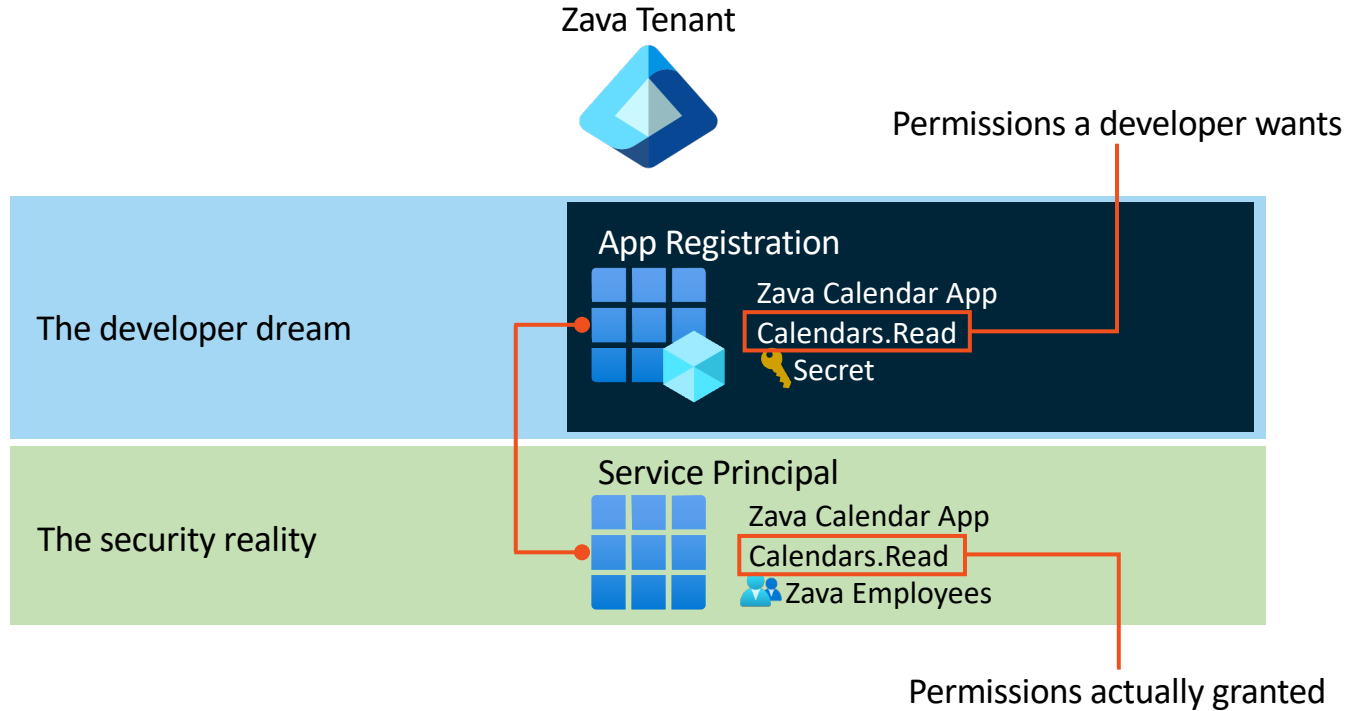
Service principal



Group

Things you can assign permissions to

App Registrations





Types of service principals



Service principal



Application



ManagedIdentity



SocialIdp



Legacy



Logical types of service principals



Service principal



Microsoft



Application



OIDC / OAuth



Agent ID

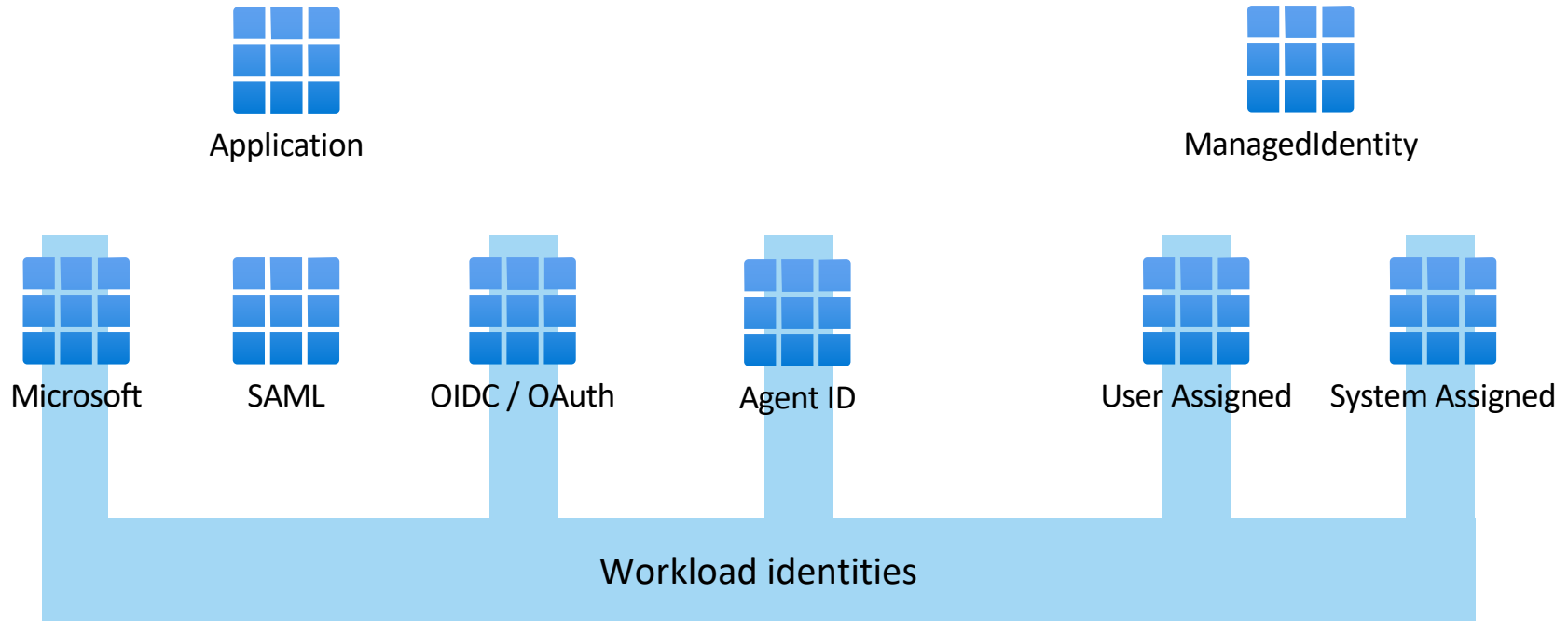


User Assigned



System Assigned

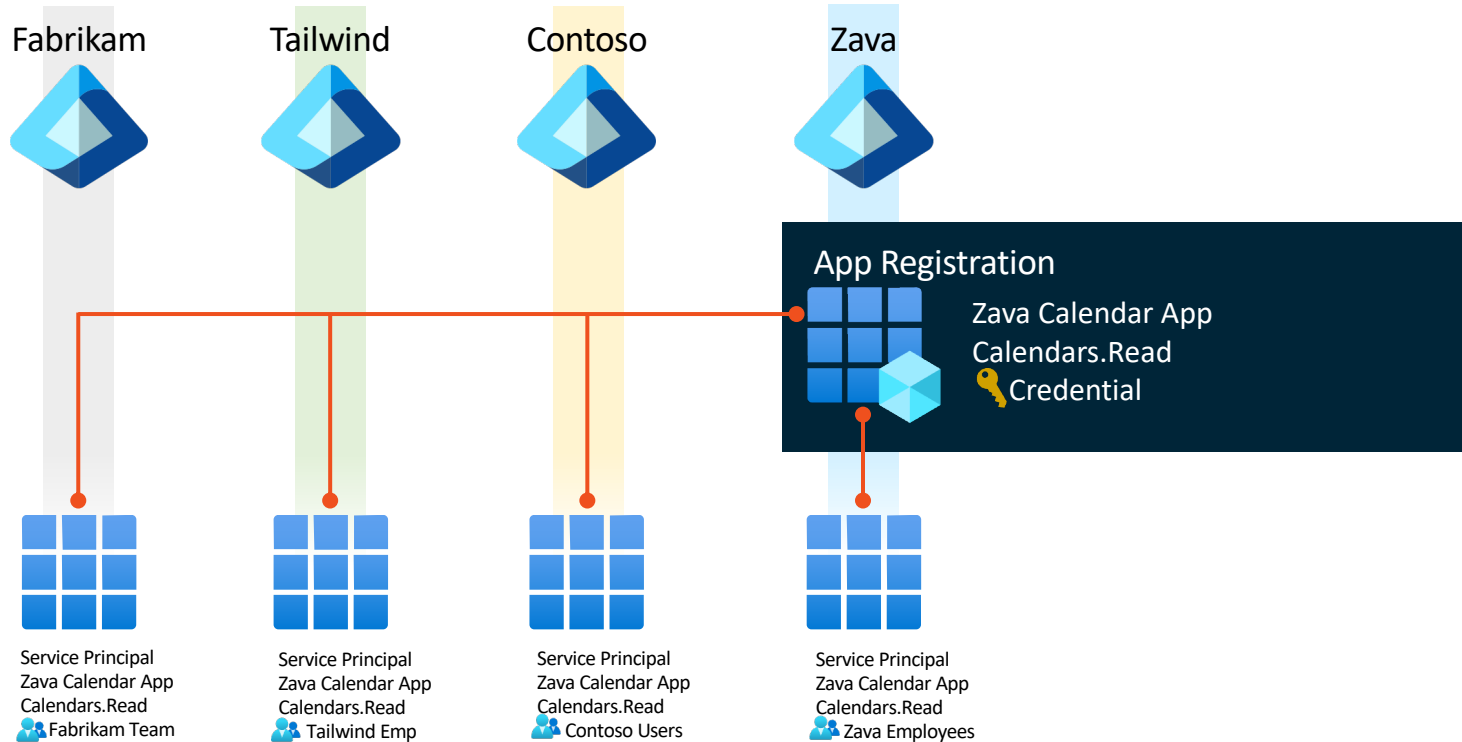
Workload identities



Single-tenant application



Multi-tenant application



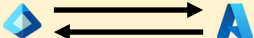
Different types of credentials

App Registration

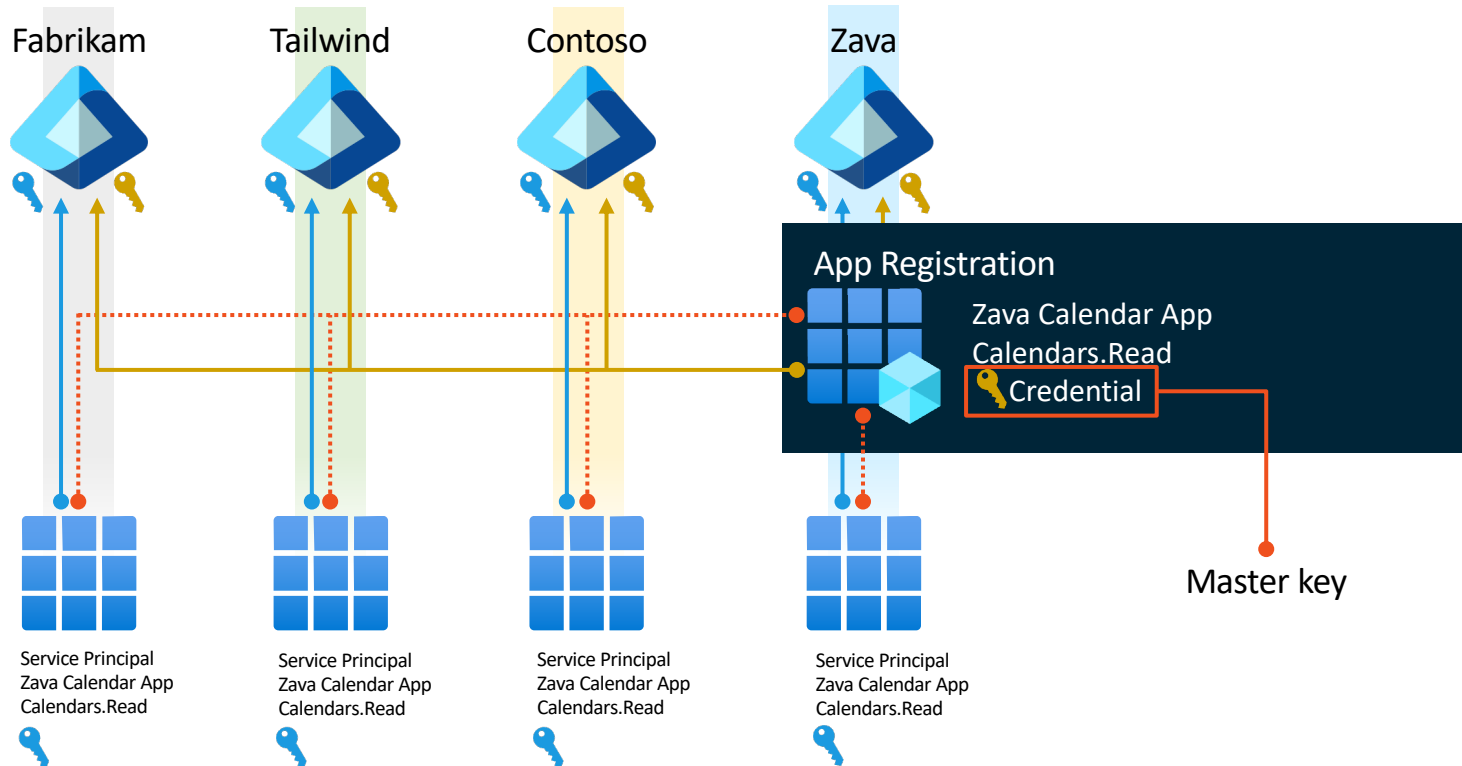


Service Principal

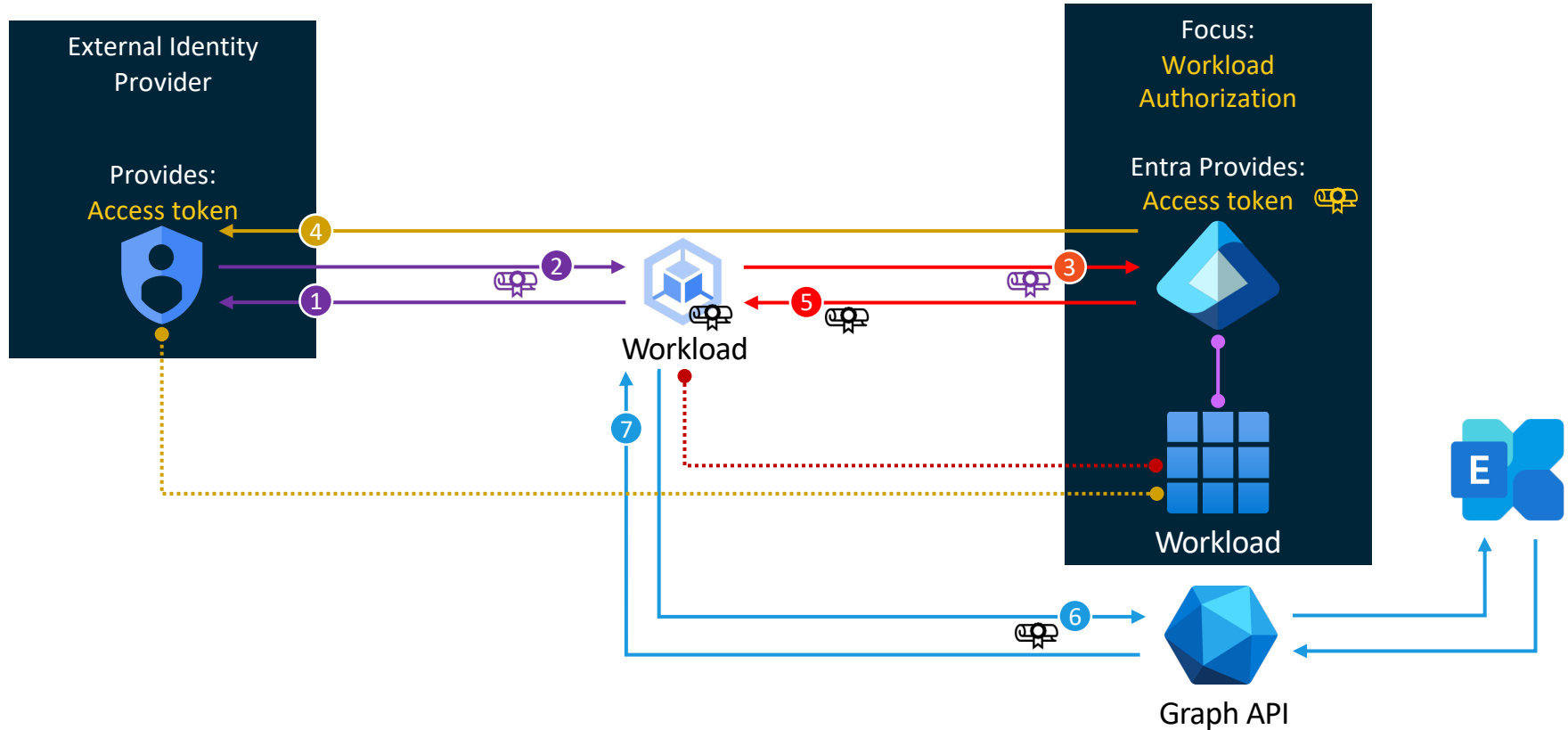


Good?	Better	Best	Best
Secret ***** A password Has a lifetime Can be leaked	Certificate  Asymmetric keypair Has a lifetime Can be leaked	Managed Identity  For Azure workloads Removes credential handling Difficult to leak	Federated Credential  A trust relationship Removes credential handling Cannot be leaked

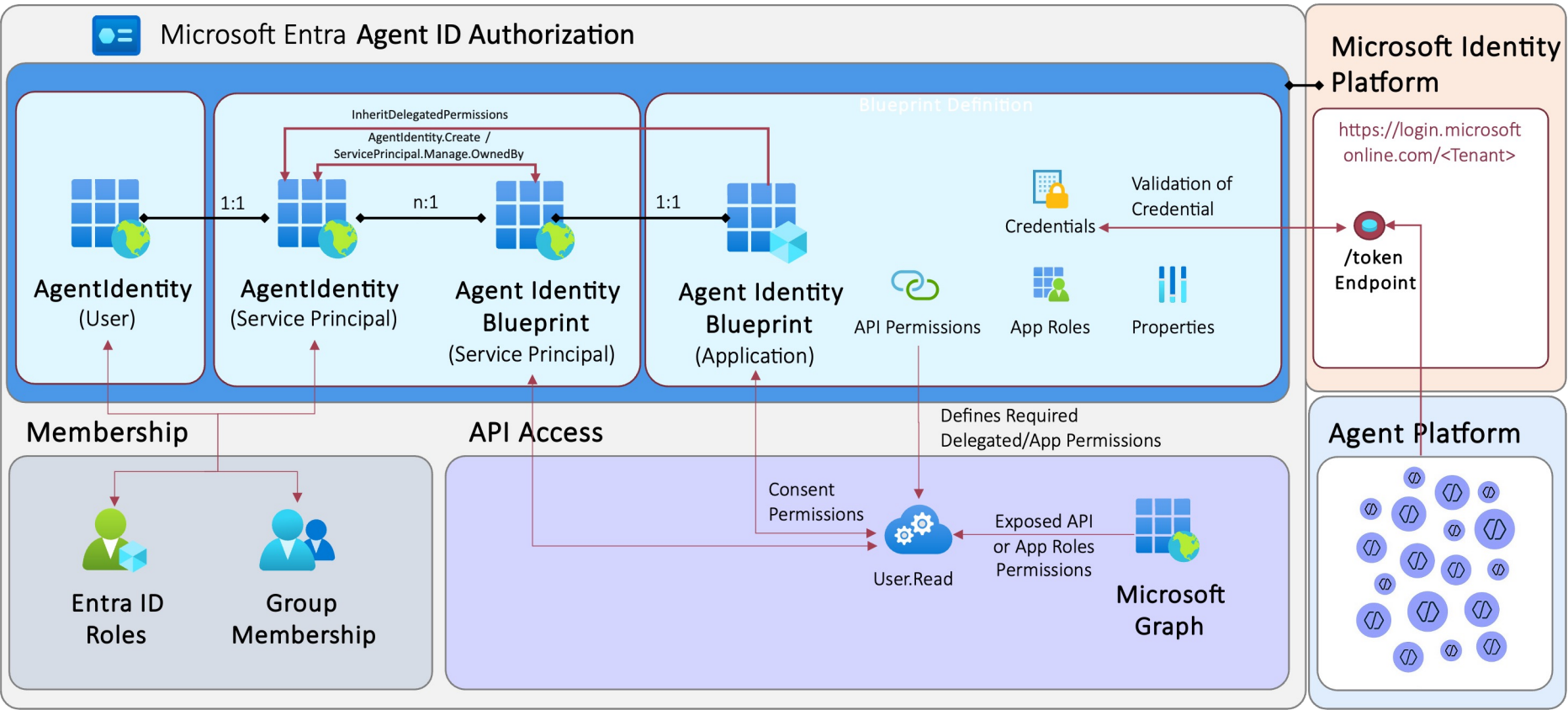
Credentials in multi-tenant scenarios



Federated credentials



Agent ID Overview



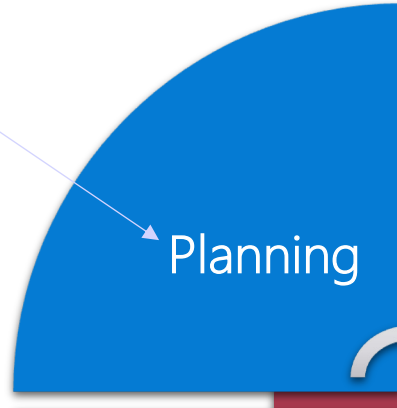


Policies and secure delegation for Workload Owners



Lifecycle phases of workload identities

- ☐ Requirements
- ☐ Type of Workload Identity
- ☐ Integration and Auth. Library
- ☐ Definition of Ownership



Critical default permissions

- By default, no limitation to require assignment to access Enterprise Apps

**Graph explorer (official site)** | Properties
Enterprise Application

Assignment required? ⓘ

Yes No

Assign users and groups to app-roles for your application here. App-roles are made available by the developer of the application by using the application registration.

☐ DU dug_AAD.PrivilegedAccounts Group Default Access

- Default permission for (Member) user on Enterprise Apps (Service Principals)

App registrations
Users can register applications ⓘ

Yes No

**Application developer**
Description: Users in this role will continue to be able to register app registrations even if the Global Admin has turned off the tenant level switch for "Users can register apps".

Default assigned ownership by creation

The screenshot displays the Microsoft Entra admin center interface. On the left is a navigation pane with categories like Home, Entra agents, Favorites, and Entra ID. The main area shows the 'Assigned roles' for a user named Montgomery Scott. The 'Active assignments' tab is active, displaying a table of role assignments. The table has columns for Role, Principal name, Scope, Membership, State, Start time, End time, and Action. One assignment is listed: 'Application Developer' assigned to 'scotty@corp.cloud-arch...' with a 'Directory' scope and 'Direct' membership, starting on 12/16/2025.

Role	Principal name	Scope	Membership	State	Start time	End time	Action
Application Developer	scotty@corp.cloud-arch...	Directory	Direct	Active	12/16/2025, 7:27:08 ...	12/16/2025, 10:25:04...	Remove U



Custom Roles for App Registration

 **Application Creator without Owner** | Description ...

Privileged Identity Management | Microsoft Entra roles

>>

 Edit

 Delete

 Got feedback?

Summary

Name:

Application Creator without Owner

Description:

Users in this role will be able to register app registrations without becoming owner.

Template ID:

b6dda220-f45d-4348-8cdb-db0033cd795b

Role permissions

microsoft.directory/applications/create	Create all types of applications
microsoft.directory/servicePrincipals/create	Create service principals

Custom Roles for App Registration

[Home](#) > [All roles](#) >

New custom role ...

All roles



Got feedback?

☐	microsoft.directory/applications.myOrganization/allProperties/read	Read all properties (including privileged properties) on single-directory applica...	
☐	microsoft.directory/applications.myOrganization/allProperties/update	Update all properties (including privileged properties) on single-directory appli...	PRIVILEGED
☐	microsoft.directory/applications.myOrganization/audience/update	Update audience on single-directory applications	
☐	microsoft.directory/applications.myOrganization/authentication/update	Update authentication on single-directory applications	
☐	microsoft.directory/applications.myOrganization/basic/update	Update basic properties on single-directory applications	
☐	microsoft.directory/applications.myOrganization/credentials/update	Update credentials on single-directory applications	PRIVILEGED
☐	microsoft.directory/applications.myOrganization/delete	Delete single-directory applications	
☐	microsoft.directory/applications.myOrganization/owners/read	Read owners on single-directory applications	
☐	microsoft.directory/applications.myOrganization/owners/update	Update owners on single-directory applications	
☐	microsoft.directory/applications.myOrganization/permissions/update	Update exposed permissions and required permissions on single-tenant applic...	
☐	microsoft.directory/applications.myOrganization/standard/read	Read basic properties on single-directory applications	
☐	microsoft.directory/applications/allProperties/read	Read all properties (including privileged properties) on all types of applications	
☐	microsoft.directory/applications/allProperties/update	Update all properties (including privileged properties) on all types of applicatio...	PRIVILEGED
☐	microsoft.directory/applications/applicationProxy/read	Read all application proxy properties	
☐	microsoft.directory/applications/applicationProxy/update	Update all application proxy properties	
☐	microsoft.directory/applications/applicationProxyAuthentication/update	Update authentication on all types of applications	

Add Custom Role for Credential Management with PIM policies

Microsoft Entra admin center

Home > All roles > New custom role > Roles and administrators | All roles > Cloud Application Secret Manager | Assignments >

Roles and administrators | All roles

CloudLab

+ New custom role Delete custom role Download assignments Refresh Preview features Got feedback?

Get just-in-time access to a role when you need it using PIM. Learn more about PIM →

There are currently 24 privileged role assignments. It is recommended to not exceed 10.

Your Role: Global Administrator and 8 other roles

Administrative roles

Administrative roles are used for granting access for privileged actions in Microsoft Entra ID. We recommend using these built-in roles for delegating access to manage broad application configuration permissions without granting access to manage other parts of Microsoft Entra ID not related to application configuration. [Learn more.](#)

[Learn more about Microsoft Entra ID role-based access control](#)

Cloud App

Role	Description	Privileged	Ass...	Type
☐ Cloud App Security Administrator	Can manage all aspects of the Cloud App Security product.		0	Built-in
☐ Cloud Application Administrator	Can create and manage all aspects of app registrations and enterprise apps except App Proxy.	PRIVILEGED	0	Built-in
☐ Cloud Application Operations			0	Custom
☐ Cloud Application Secret Manager		PRIVILEGED	0	Custom

Use PIM for Azure Roles to manage credentials

The screenshot shows the Microsoft Entra admin center interface. The left sidebar contains navigation links: Home, Entra agents, Favorites, Entra ID, Overview, Users, Groups, Devices, Agent ID (Preview), Enterprise apps, App registrations, Roles & admins, Delegated admin partners, Domain services, Conditional Access, and Multifactor authentication. The main content area is titled 'My App | Owners' and includes a search bar, '+ Add owners', 'Remove owners', and 'Got feedback?' links. A red warning message states: 'Some actions may be disabled due to your permissions. To request access, contact the application owner(s) or your administrator. View application owners or administrators.' Below this, a paragraph explains that only individual users are supported as owners of applications. A blue 'Add owners' button is prominently displayed. The bottom of the page shows a 'Support + Troubleshooting' section with a 'New support request' link.

Microsoft Entra admin center

Home > My App

My App | Owners

Search

+ Add owners Remove owners Got feedback?

Some actions may be disabled due to your permissions. To request access, contact the application owner(s) or your administrator. View application owners or administrators.

The users listed here can view and edit this application registration. Additionally, any user (may not be listed here) with administrative privileges to manage any application (e.g., Global Administrator, Cloud App Administrator etc.) can view and edit the application registrations. Currently, only individual users are supported as owners of applications. Assignment of groups as owners is not yet supported. If the user setting "Restrict access to Microsoft Entra ID administration portal" is set to Yes, non-admin users will not be able to use the Azure portal to manage the applications they own. [Learn more](#)

Manage

- Branding & properties
- Authentication (Preview)
- Certificates & secrets
- Token configuration
- API permissions
- Expose an API
- App roles
- Owners**
- Roles and administrators
- Manifest

Support + Troubleshooting

- New support request

No owners have been assigned to this application.

Add owners

Default Tenant App Management Policy

The screenshot displays the Microsoft Entra admin center interface. The left sidebar contains navigation links for Home, Entra agents, Favorites, Entra ID, Overview, Users, Groups, Devices, Agent ID (Preview), Enterprise apps, App registrations, Roles & admins, Delegated admin partners, Domain services, Conditional Access, Multifactor authentication, and Provisioning logs. The main content area is titled 'Enterprise applications | Overview' and includes a search bar for tenants. Below the search bar, there is a 'Basic information' section with a table of application statistics. To the right, there are two cards: 'Conditional Access' and 'Admin consent requests'. At the bottom, there is a card for 'Access reviews'.

Basic information	
Total applications	1,040
Enterprise applications	68
Microsoft applications	770
Enabled apps	1,033
Disabled apps	7
Hidden apps	39

Admin consent requests	
0	awaiting approval

Access reviews	
21	in progress

App Management Policy for Service Principal and Applications

Home > My App

My App | Certificates & secrets

Search resources, services, and docs (G+/)

Overview

Quickstart

Integration assistant

Diagnose and solve problems

Manage

Branding & properties

Authentication (Preview)

Certificates & secrets

Token configuration

API permissions

Expose an API

App roles

Owners

Roles and administrators

Manifest

Support + Troubleshooting

New support request

Credentials enable confidential applications to identify themselves to the authentication service when receiving tokens at a web addressable location (using an HTTPS scheme). For a higher level of assurance, we recommend using a certificate (instead of a client secret) as a credential.

Application registration certificates, secrets and federated credentials can be found in the tabs below.

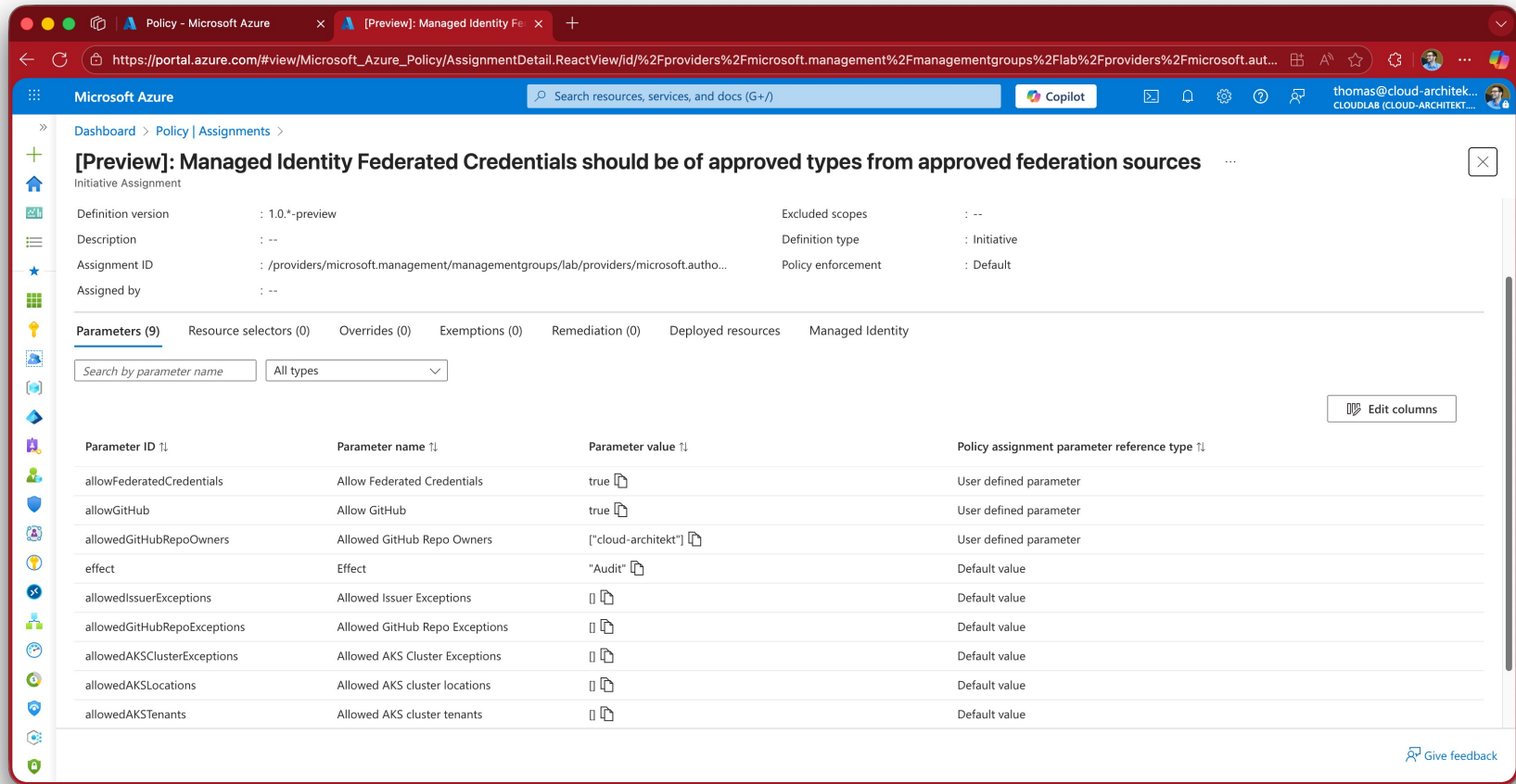
Certificates (0) **Client secrets (0)** Federated credentials (0)

A secret string that the application uses to prove its identity when requesting a token. Also can be referred to as application password.

+ New client secret

Description	Expires	Value	Secret ID
No client secrets have been created for this application.			

Azure Policy to restrict Federated Credentials for Managed Identities



The screenshot shows the Azure Portal interface with the following details:

- Page Title:** [Preview]: Managed Identity Federated Credentials should be of approved types from approved federation sources
- Definition version:** 1.0.*-preview
- Description:** --
- Assignment ID:** /providers/microsoft.management/managementgroups/lab/providers/microsoft.autho...
- Assigned by:** --
- Excluded scopes:** --
- Definition type:** Initiative
- Policy enforcement:** Default

Parameters (9)

Parameter ID	Parameter name	Parameter value	Policy assignment parameter reference type
allowFederatedCredentials	Allow Federated Credentials	true	User defined parameter
allowGitHub	Allow GitHub	true	User defined parameter
allowedGitHubRepoOwners	Allowed GitHub Repo Owners	["cloud-architekt"]	User defined parameter
effect	Effect	"Audit"	Default value
allowedIssuerExceptions	Allowed Issuer Exceptions		Default value
allowedGitHubRepoExceptions	Allowed GitHub Repo Exceptions		Default value
allowedAKSClusterExceptions	Allowed AKS Cluster Exceptions		Default value
allowedAKSLocations	Allowed AKS cluster locations		Default value
allowedAKSTenants	Allowed AKS cluster tenants		Default value



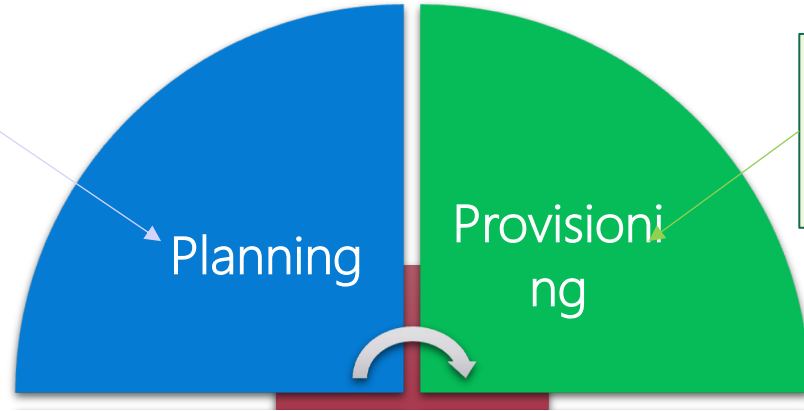
Lifecycle phases of workload identities

- ☐ Requirements
- ☐ Type of Workload Identity
- ☐ Integration and Auth. Library
- ☐ Definition of Ownership

Planning

Provisioning

- ☐ Create workload identity
- ☐ Assignment of Permissions
- ☐ Delegation and Classification
- ☐ Issuing credentials (if needed)



Manage API Permissions in Identity Governance

Microsoft Entra admin center Search resources, services, and docs (G+)

Home > Identity Governance | Access packages >

New access package

Who can get access *

- ☒ For users, service principals, and agent identities in your directory
Allow users, groups, service principals, and agent identities in your directory to get access to this access package
- ☐ For users not in your directory
Allow users in connected organizations (other directories and domains) to get access to this access package
- ☐ None (administrator direct assignments only)
Allow administrators to directly assign specific users to this access package. No subjects can get access without being explicitly assigned by administrator.

Select specific scope

- ☐ Specific users and groups
- ☐ All members (excluding guests)
- ☐ All users (including quests)
- ☒ All service principals (preview)
- ☐ All agents (preview)

Who can request access

Who can request access *

- ☒ Self
- ☒ Admin
Admin can't be turned off because admins will always be able to assign users to an access package.
- ☐ Manager
- ☒ Service Principal Owner

Approval

Review + create Previous Next: Requestor Information >

Manage API Permissions in Identity Governance

Microsoft Entra admin center

Search resources, services, and docs (G+/)

Copilot

2

thomas@cloud-architek...
CLOUDLAB (CLOUD-ARCHITEKT...

Home > Identity Governance | Access packages >

New access package

* Basics

Resource roles

* Requests

Requestor information

* Lifecycle

Custom extensions

Review + create

Add different resources to this access package. Specify the permissions associated with each resource by selecting a role from the drop-down list. [Learn more](#)

+ Groups and Teams

+ Applications

+ SharePoint sites

+ Microsoft Entra role (Preview)

+ API Permissions (Preview)

Resource	Type	Sub Type	Role Type	Role *	
Microsoft Graph	OAuthApplication	API	Application	User.ReadBasic.All	
Microsoft Graph	OAuthApplication	API	Delegated	openid	
Microsoft Graph	OAuthApplication	API	Delegated	profile	

Review + create

Previous

Next: Requests >



Exploring the surface area for risk

Exposed credentials

- Repots can be scanned for publicly exposed credentials
- The focus tends to be on secret scanning, but any credential such as a private key can also be abused
- Detection of credentials is not the same as prevention

×

 **Secret scanning** found a Azure Active Directory Application Secret secret on [line 4](#).

Allowing this secret risks exposure. Instead, consider [removing the secret from your commit and commit history](#).

Exposing this secret can allow someone to:

- Verify the identity of this Azure Active Directory Application Secret secret
- Know which resources this secret can access
- Act on behalf of the secret's owner
- Push this secret to this repository without being blocked

☐ It's used in tests
The secret poses no risk. If anyone finds it, they cannot do any damage or gain access to sensitive information.

☐ It's a false positive
The detected string is not a secret.

☐ I'll fix it later
The secret is real, I **understand the risk**, and I will need to revoke it. This will open a security alert and notify admins of this repository.

Abusing publicly exposed application credentials

The screenshot shows a web browser displaying the GitHub repository page for 'ericonidentity/demoapp'. The repository is public and has 1 branch (main) and 0 tags. The commit history shows three commits: 'Initial commit' (47 minutes ago), 'Add appinfo file with application details' (41 minutes ago), and 'Add files via upload' (39 minutes ago). The README file is titled 'demoapp'.

GitHub - ericonidentity/demoapp

Platform Solutions Resources Open Source Enterprise Pricing

Search or jump to... Sign in Sign up

ericonidentity / demoapp Public

Notifications Fork 0 Star 0

<> Code Issues Pull requests Actions Projects Security Insights

main 1 Branch 0 Tags

Go to file Code

ericonidentity Add files via upload f0cd037 · 39 minutes ago 3 Commits

README.md	Initial commit	47 minutes ago
appinfo	Add appinfo file with application details	41 minutes ago
highlyprivileged.pem	Add files via upload	39 minutes ago

README

demoapp

About

No description, website, or topics provided.

- Readme
- Activity
- 0 stars
- 0 watching
- 0 forks

Report repository

Releases

No releases published

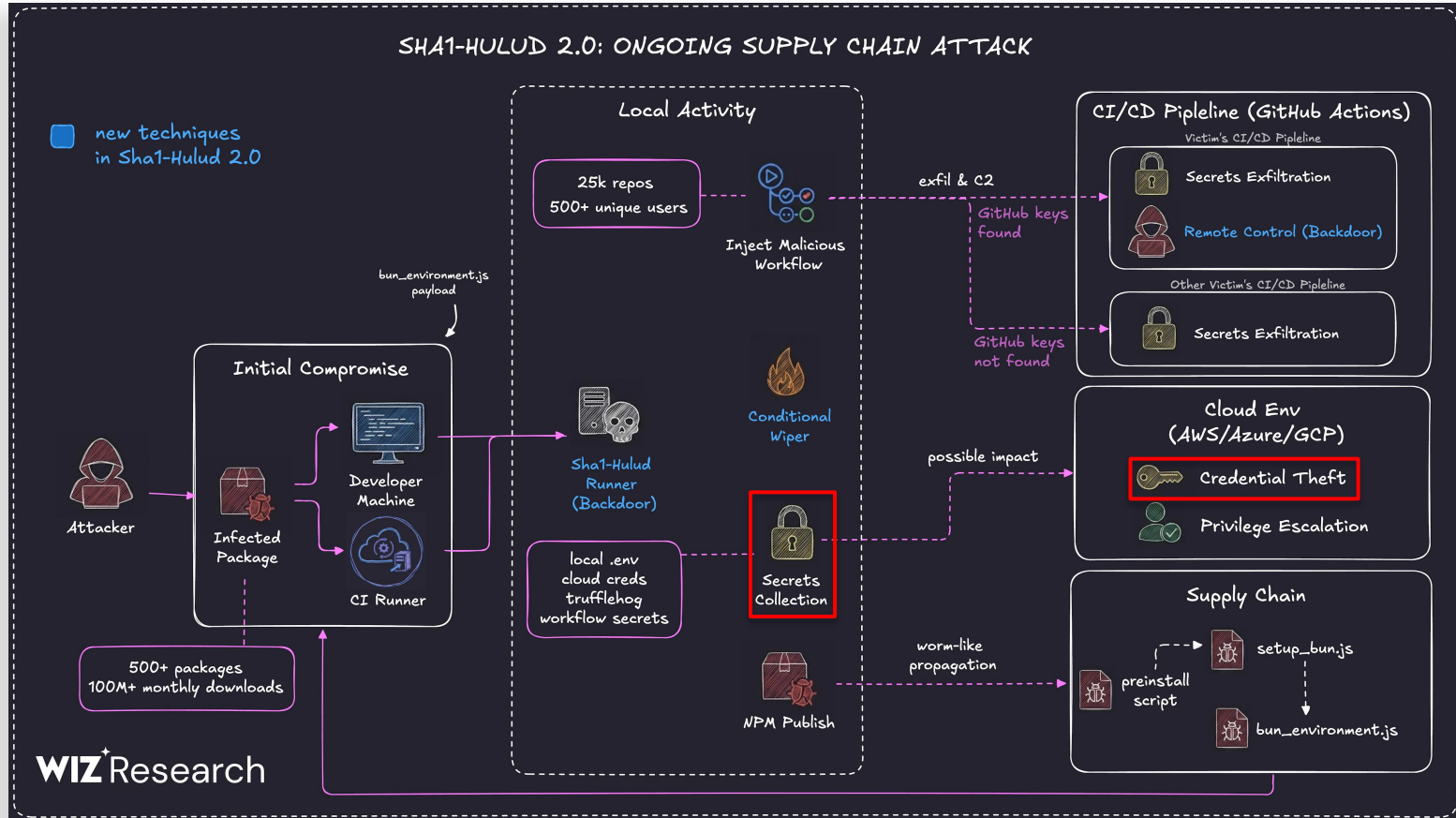
Packages

No packages published

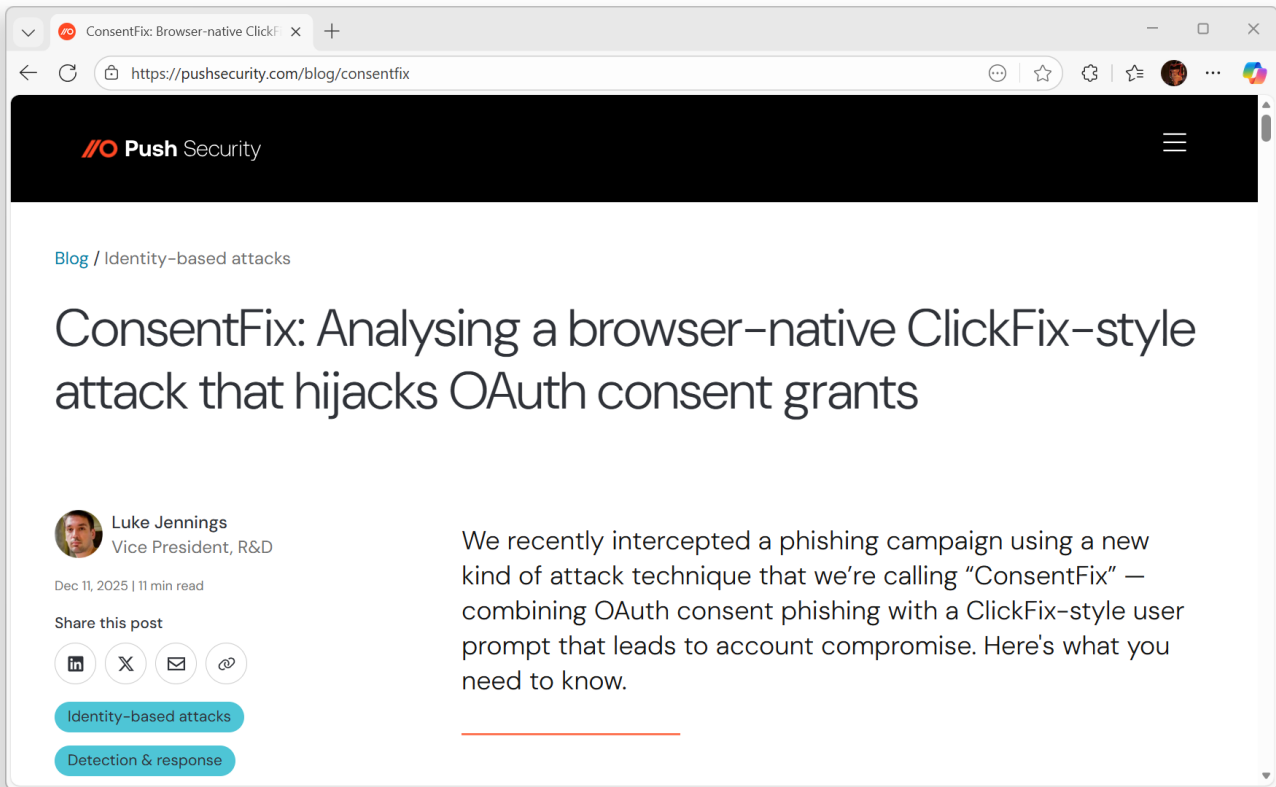
© 2025 GitHub, Inc. Terms Privacy Security Status Community Docs Contact Manage cookies Do not share my personal information

911 PM 12/29/2025

Sophisticated secret theft through supply chain attacks



Abusing Redirect URIs





ConsentFix

- Abuses privileged Microsoft applications
- Is an evolution of ClickFix attacks
- Allows an attacker to obtain an authorization code
- Attacker redeems the authorization code for an access token

Verify you are human by completing the action below.

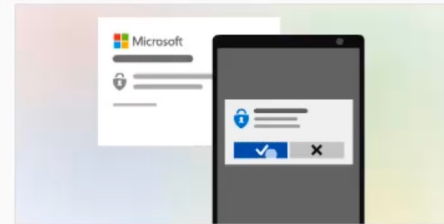
victim@company.com

Paste URL to allow access

Sign in to your Microsoft account to verify your identity and after successful authentication, copy the URL received and paste it below.

http://

Sign in





ConsentFix

Entr

Sign-in URL Builder - Gene

+

https://signin.merill.net

Merill.Net

Entr

News

About

X

in

Private (3)

**Microsoft Entra Sign-in URL Builder**
Generate OAuth 2.0 authorization URLs for Microsoft Entra ID

 Sign in with Microsoft

 **Microsoft Entra Sign In URL**

 Fill in the required fields below to generate your sign-in URL

https://login.microsoftonline.com/organizations/oauth2/v2.0/authorize?response_type=code

 Copy URL to Clipboard

 **Authorization URL** 

Generate URLs for user authentication and authorization to access resources on their behalf

 **Admin Consent URL** 

Generate URLs for administrators to grant tenant-wide permissions to applications

 **Base Configuration**

Base URL Type

 **Common**
Any organization

 **Specific Tenant**
Single organization

 **Consumers**

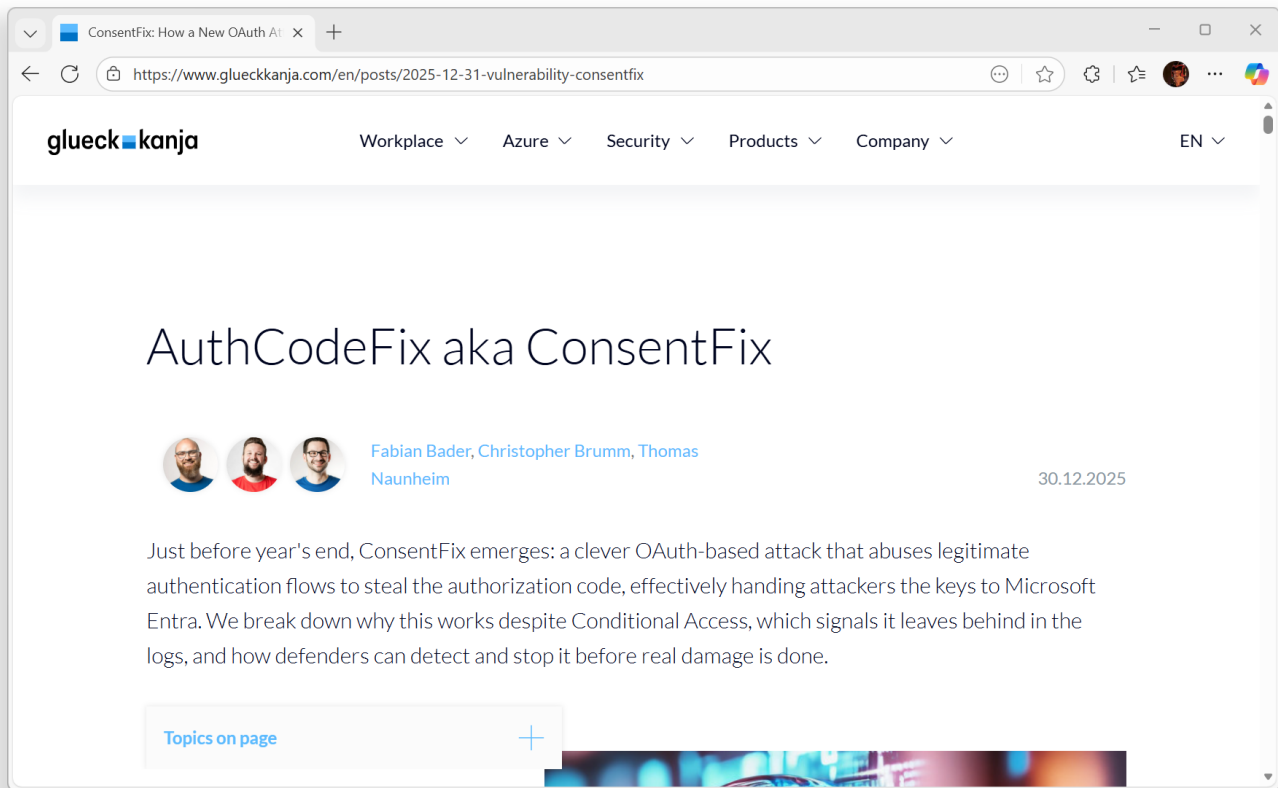
 **Organizations** 

4:42 PM

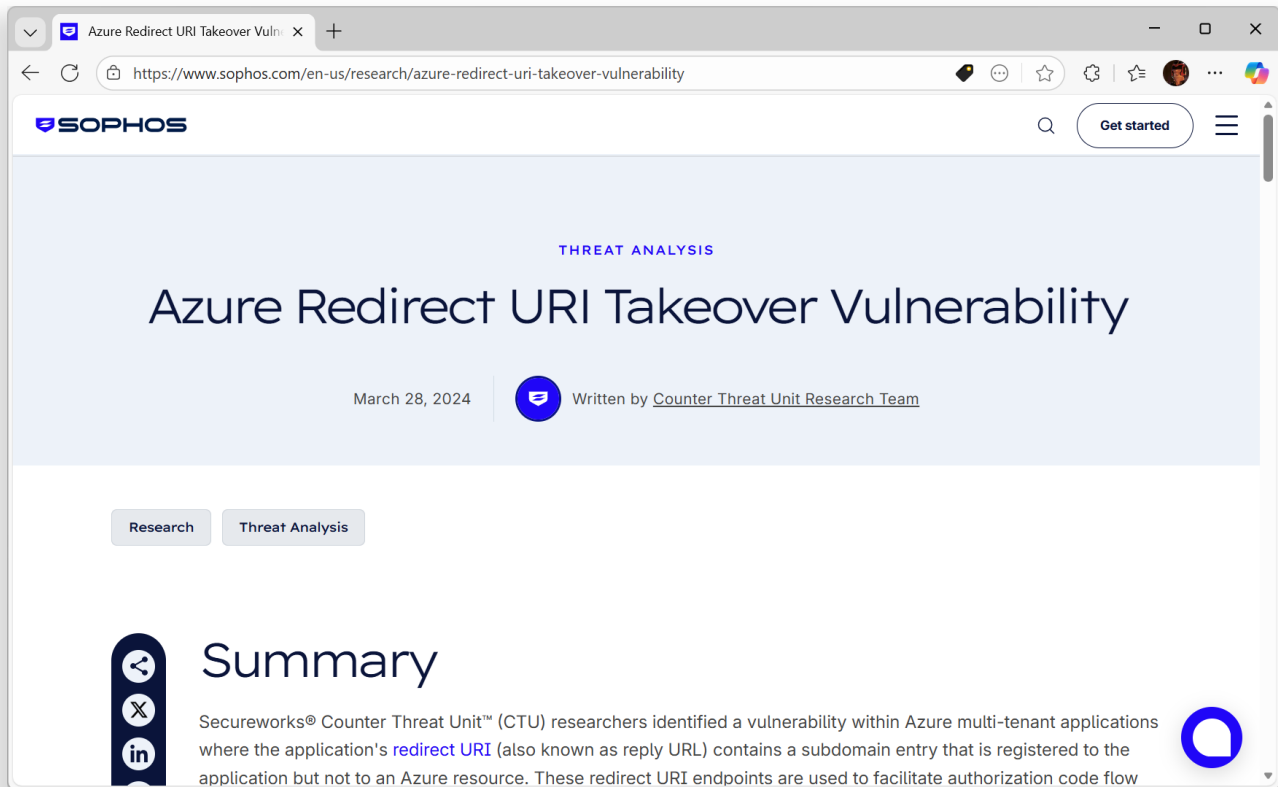
1/5/2026



ConsentFix



Abusing Redirect URIs





Redirect URI Takeover

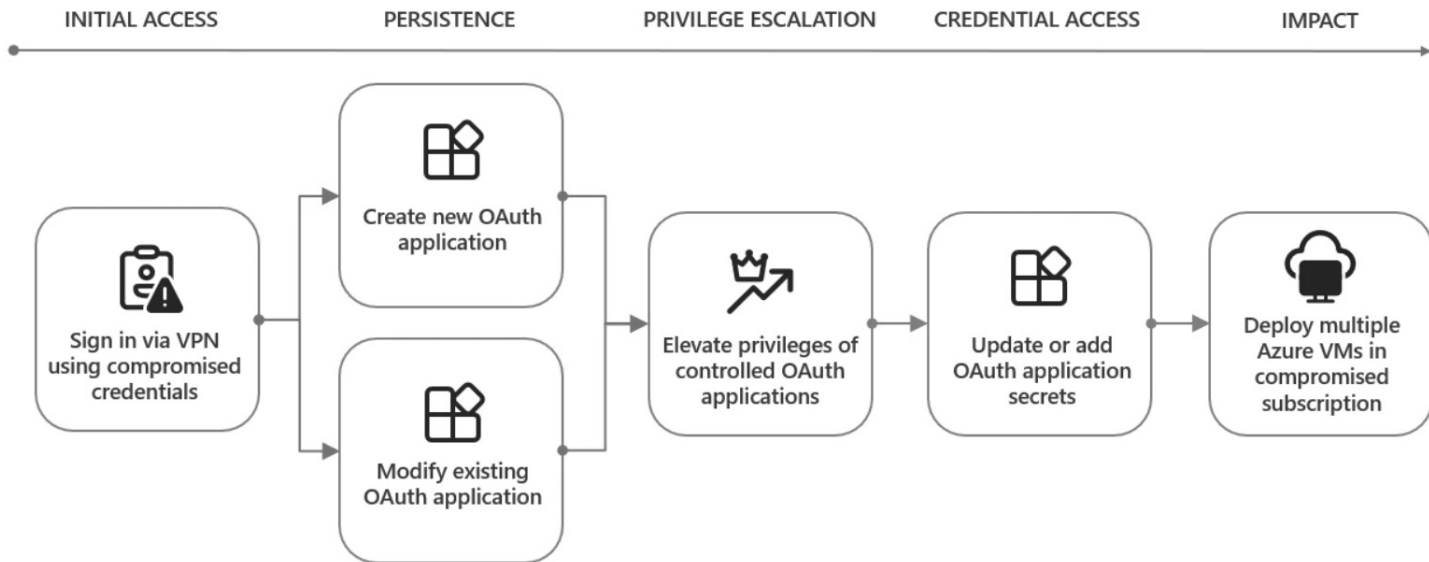
- Can be used to abuse 3rd party applications
- Attacker finds dangling hostnames on service principals
- Allows an attacker to obtain an authorization code
- Attacker redeems authorization code for an access token

Attackers Service Principals



Storm-1283

OAuth applications to deploy VMs for cryptomining



Source: [Threat actors misuse OAuth applications to automate financially driven attacks](#)



Lifecycle phases of workload identities

- ☐ Requirements
- ☐ Type of Workload Identity
- ☐ Integration and Auth. Library
- ☐ Definition of Ownership

Planning

Provisioning

- ☐ Create workload identity
- ☐ Assignment of Permissions
- ☐ Delegation and Classification
- ☐ Issuing credentials (if needed)

Deprovisioning

Monitor and maintaining

- ☐ Remove association
- ☐ Revoke permissions
- ☐ Review ongoing activity
- ☐ Delete workload identity

- ☐ Activity and used permissions
- ☐ Suspicious sign-in or changes
- ☐ Delegations and Ownership
- ☐ Change/renewal credentials



Nation-state attack by “Midnight Blizzard”

Malicious use of OAuth applications

Threat actors like Midnight Blizzard compromise user accounts to create, modify, and grant high permissions to OAuth applications that they can misuse to hide malicious activity. The misuse of OAuth also enables threat actors to maintain access to applications, even if they lose access to the initially compromised account. Midnight Blizzard leveraged their initial access to identify and compromise a **legacy test OAuth application that had elevated access to the Microsoft corporate environment**. The actor created additional malicious OAuth applications. They created a new user account to grant consent in the Microsoft corporate environment to the actor controlled malicious OAuth applications. The threat actor then used the legacy test OAuth application to grant them the Office 365 Exchange Online ***full_access_as_app* role, which allows access to mailboxes**.



XDR Threat Protection and Security Posture

App Inventory and Insights for SOC by using WorkloadIdentityInfoXDR

The screenshot displays the Microsoft Defender Advanced Hunting interface. The browser address bar shows the URL: <https://security.microsoft.com/v2/advanced-hunting?tid=36955ea9-c98e-4749-b603-ffefe652dd90>. The page title is "Advanced hunting". The selected workspace is "lab-la-4d3e5b65-8a52-4b2f-b5cd-1670c700136b".

The interface shows a query named "WorkloadIdentityInfoXdr" with the following results:

ServicePrincipalName	ServicePrincipalId	OAuthAppId	CriticalityLevel	AddedOnTime	LastModifiedTime	AppStatus	VerifiedPublisher
> aadexporter-sp	ad4f7ea9-521d-422c-a3...	20f7a103-e7eb-49cf-9cf...		May 13, 2021 1:22:38 PM		Enabled	{}
> aadops-pull-sp	01b83e5e-ea2-40cc-92...	8d49d8d1-c448-4996-a...		Jan 18, 2021 2:48:11 PM		Enabled	{}
> ASPADev	5892a25b-509f-4f3e-acc...	1309b33f-ecf2-4786-aa1...		Jul 1, 2025 11:24:59 AM		Enabled	{}
> AzADServicePrinci...	d91eeca-9fc9-49d3-aaa...	e7843299-6dab-4683-8...		Apr 9, 2022 10:56:57 PM		Enabled	{}
> AzGovViz	4434a136-a704-4306-8...	34f7258a-81a0-4f72-bbf...		Jan 11, 2022 9:21:48 AM	Jun 12, 2023 11:52:48 AM	DisabledByUser	{}
> azops-pull-sp	deea7af6-3531-41a0-b8...	e96c653b-9ea0-4bcf-b0...		Oct 18, 2020 9:38:28 AM		Enabled	{}
> AzSentinel-Playbo...	1c334d68-ce72-4efa-a0...	5d6db40a-65a4-4fb2-a...		Sep 10, 2021 9:04:48 AM		Enabled	{}
> Azure AD Terraform	86c4ff0b-b24d-431f-b5...	acc97b04-e430-4541-99...	1	Nov 21, 2022 7:40:01 PM		Enabled	{}
> Azure Logic Apps ...	3037993f-35f8-46d2-be...	b2a54184-d0c5-4c6a-af...		Mar 26, 2021 12:18:05 PM		Enabled	{}

Detection Query: [Cloud-Architekt/AzureSentinel - WorkloadIdentityInfoXdr](#)

zava

Microsoft Defender

Search

Settings > Microsoft Defender XDR

Microsoft Defender XDR

Email notifications

Advanced features

Permissions and roles

Streaming API

Rules

Asset rule management

Alert tuning

Critical asset management

Service accounts classification

Phishing Triage Agent

Overview

Feedback

Threat Intelligence Briefing Agent

Overview

Identity and role

Configuration

Create a new classification

Classification	Status	Assets	Pending approval	Criticality level
SPN with Critical App Permissions to OneDrive & SharePoint Management	On	0	-	Critical
SPN with Critical App Permissions to Users and Groups Management	On	7	-	Critical
SPN with Critical App Permissions to Security Management	On	1	-	Critical
SPN with Critical App Permissions to Organization Management	On	0	-	Critical
SPN with Critical App Permissions to Domain Management	On	0	-	Critical
SPN with Critical App Permissions to Mail Management	On	4	-	Critical
SPN with Critical App Permissions to Print Management	On	0	-	Critical
SPN with Critical App Permissions to On-Premises Management	On	0	-	Critical
SPN with Critical App Permissions to User Shift Management	On	0	-	Critical
SPN with Critical App Permissions to Teams Management	On	0	-	Critical
SPN with Critical App Permissions to Applications Management	On	2	-	Critical
SPN with Critical App Permissions to Device Management	On	4	-	Critical
SPN with Critical App Permissions to Identity and Access Management	On	2	-	Critical
SPN with Critical Delegated Permissions to Identity and Access Management	On	0	-	Critical

SPN with Critical App Permissions to Users and Groups Management

Turn off Report inaccuracy

OverviewAssets

The assets below are classified as critical assets for your organization.

7 items

Asset name	Date found
ac790aff-610b-49e4-99...	8/28/2025
1ff06caf-ddaa-4363-86...	12/12/2025
bf9ed526-3844-423f-b...	8/5/2024
35c661a1-5e21-4b38-a7...	10/8/2025
9944cde6-68dc-42e4-b...	8/5/2024
a2e9bef3-fc5f-401d-b2...	8/1/2024
27bf9e71-106d-49bd-b...	7/12/2025



Application and Service Principal Checks in Maester

Home

View

Markdown

Excel

Print

Settings

Failed

Pass 14%

Fail 86%

Search by ID or Title...

Category

ID ↑	Title
MT.1002	App management restrictions on applic
MT.1027	No Service Principal with Client Secret
MT.1050	Apps with high-risk permissions having
MT.1051	Apps with high-risk permissions having
MT.1077	App registrations with privileged API pe
MT.1078	App registrations with highly privileged
MT.1079	Privileged API permissions on service p

X < 7/7 >

Medium Failed

MT.1079: Privileged API permissions on service principals should not remain unused.

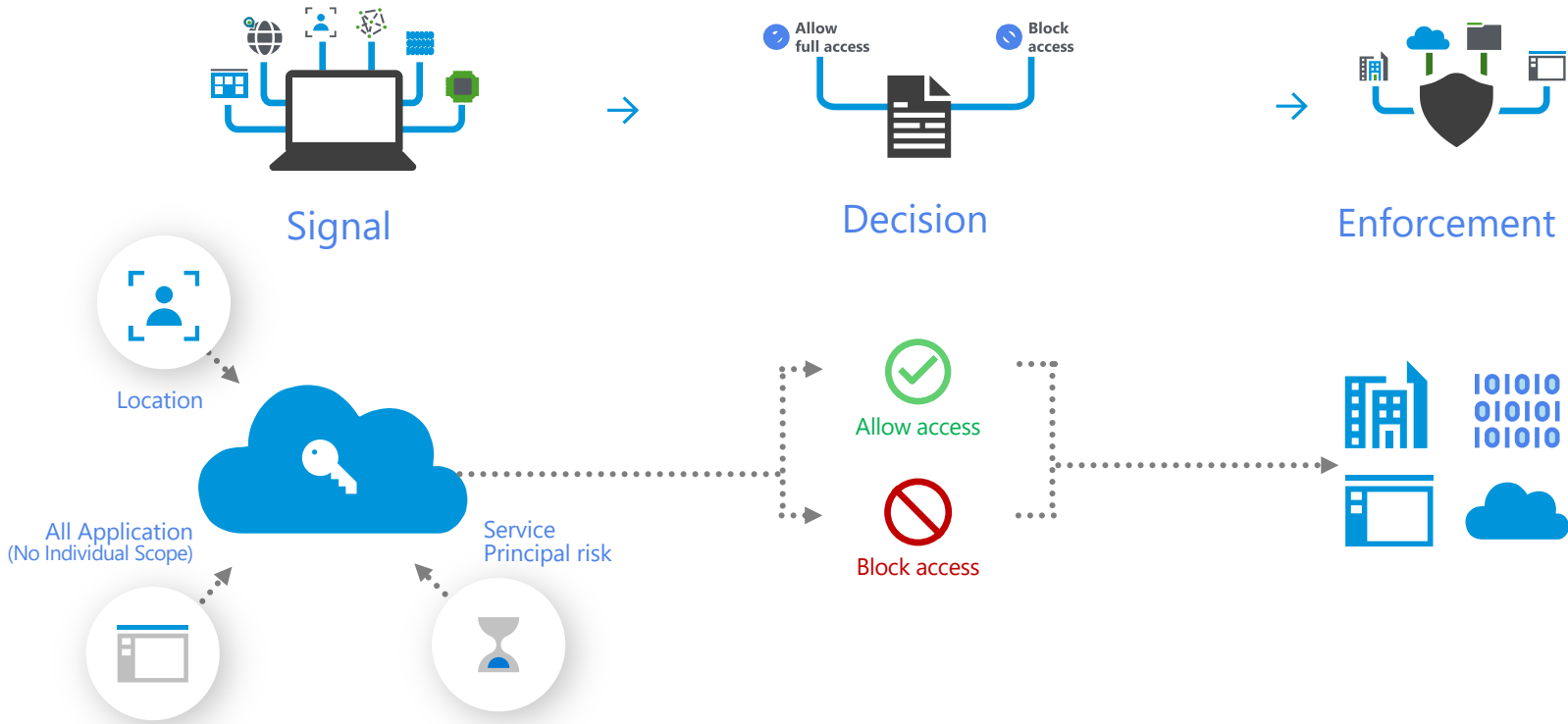
[Learn more @ maester.dev](#)

Test result

At least one application has unused sensitive API permissions.

ApplicationName	Enterprise Access Level	Sensitive App Role	API Provider
CloudFileBackup	ManagementPlane	Files.ReadWrite.All	Microsoft Graph
CloudFileBackup	ManagementPlane	Mail.ReadWrite	Microsoft Graph
CloudFileBackup	ManagementPlane	Sites.ReadWrite.All	Microsoft Graph
MyFirstAgentId	ManagementPlane	Mail.Read	Microsoft Graph
OneDriveBackup	ManagementPlane	Files.ReadWrite.All	Microsoft Graph
OneDriveBackup	ManagementPlane	Mail.ReadWrite	Microsoft Graph
OneDriveBackup	ManagementPlane	Sites.ReadWrite.All	Microsoft Graph
Graph Explorer	ManagementPlane	Mail.Read	Microsoft Graph
Graph Explorer	ManagementPlane	Mail.ReadBasic	Microsoft Graph
Graph Explorer	ManagementPlane	Mail.ReadWrite	Microsoft Graph
Graph Explorer	ManagementPlane	Sites.Read.All	Microsoft Graph
MS Cloud 365 Management	ManagementPlane	Files.ReadWrite.All	Microsoft Graph
MS Cloud 365 Management	ManagementPlane	Mail.Read	Microsoft Graph
MS Cloud 365 Management	ManagementPlane	Mail.Send	Microsoft Graph

Conditional access for workload identities



Conditional Access for Workload Identities

The screenshot displays the Microsoft Entra admin center interface. The left sidebar contains navigation links for Overview, Users, Groups, Devices, Agent ID (Preview), Enterprise apps, App registrations, Roles & admins, Delegated admin partners, Domain services, Conditional Access, Multifactor authentication, Identity Secure Score, Authentication methods, Account recovery (Preview), Password reset, Custom security attributes, and Certificate authorities. The main content area is titled 'Conditional Access | Policies' and shows a summary of policies. It includes three cards: 'Conditional Access Optimization Agent' with 2 policies created, 'Microsoft-managed policies' with 0 policies created, and 'User created policies' with 69 policies created. Below these cards is a search bar with the filter 'Workloads' applied, showing 2 out of 71 policies found. The table below lists the policies:

Policy name	Created by
401 - ALL - Workloads - Self Hosted Agent Pipelines: Block access from untrusted network locations	USER
402 - ALL - Workloads - High-privileged Workload Identity: Block access For When high workload identity risk is detected	USER



Workload Identities Premium?

Feature	Free (Entra ID License)	Premium (\$3/Month/Service Principal)
Authentication, Authorization, Sign-in and Audit Logs	Yes	Yes
Conditional Access	No	Yes
Access Reviews	No	Yes
Identity Protection	No	Yes
App Management Policies	Yes	Yes
App Health Recommendations	Yes	Yes
MDA App Governance	Add-on to MDA, free for E5 customers (since June 1 st , 2023)	

Multi-Stage Attack on Application Identity

Zava Microsoft Defender

Search

Incidents > Compromised user account used to create a malicious OAuth application (attack disruption)

ID 36281: Compromised user account used to create a malicious OAuth application (attack disrupti...

Copilot Manage incident End analyst notes

High Resolved Defender Experts Unclassified Last update time: Dec 10, 2025 3:43 PM Critical asset OAuth App Abuse Attack Disruption ninjashow

Attention: Attack disruption initiated multiple response actions. For more details, go to the Activities tab or visit the Action center.

Attack story Alerts (5) Assets (2) Investigations (0) Evidence and Response (14) Summary Similar incidents (0)

Creation time
Dec 3, 2025 10:13:25 AM

Alerts

Dec 3, 2025 10:13 AM Resolved
Activity from a TOR IP address (preview)
Elvia Atkins

Dec 3, 2025 10:13 AM Resolved
Malicious OAuth application added by compromised user
Elvia Atkins Microsoft-App

Dec 3, 2025 10:13 AM Resolved
Suspicious OAuth app-related activity by compromised user
Elvia Atkins

Dec 3, 2025 10:16 AM Resolved
Suspicious OAuth app registration
Elvia Atkins

Dec 3, 2025 10:38 AM Resolved
Compromised user account in a recognized attack pattern
Elvia Atkins

Incident graph Layout Group similar nodes

```
graph TD; elvia((elvia)) --- cloud((3 Cloud Applications)); elvia --- ips((8 IPs)); cloud -.- oAuth((2 OAuth Applications)); ips -.- oAuth; oAuth -.- cloud; oAuth -.- ips
```

— Communication - - - Association

Microsoft Edge Beta

Report incident inaccuracy

Summary | Take Aways



Consider secure implementation of authentication library, storing credentials and token caching
Avoid long-term credentials and verify security of trusted entities for Workload Identity Federation
Implement application management policy to govern credential issuing



Implement an application and lifecycle management
Consider Entra roles and ownership with permissions on application/service principal objects
Classify your application to detect privilege escalation paths and sensitivity of workload identity



Apply Conditional Access Policies for Service Principals and monitor risk detection
Monitor used/unused permissions and activity (IP address and type of access) after AuthN/AuthZ
Implement playbooks to automate response on suspicious sign-in or activity of service principals



Deploy rule templates and integrate MDA App Governance
Build detection to build correlation and enrichment by classification data
Monitor trusted entities/IdP (for Federated Credentials) and resources with assigned MSI particularly
Review and integrate enriched data by OAuthAppInfo and IdentityInfo